

Unmasking the Threat

Analysis of an Agent Tesla Phishing Vector — DFIR / Malware Analysis Case Study

Disclaimer: This analysis was performed on a simulated phishing email inside an isolated training lab (MailHog / GoPhish). No production systems or real recipients were involved. The indicators of compromise (IP, domain, file hash) relate to publicly documented Agent Tesla samples already catalogued on public threat-intelligence platforms (VirusTotal, Tria.ge, Malpedia).

Executive Summary

A simulated phishing email was analysed in a controlled lab environment. The investigation confirmed, with high confidence, that the email was a malicious attack designed to deliver Agent Tesla, an information-stealing Trojan.

The email spoofed a legitimate sender and used social-engineering tactics, urging the recipient to open an attachment disguised as a "Statement of Account." The key technical findings proving its malicious nature were a failed SPF authentication check (indicating a forged sender) and a definitive malware match on the attachment — 50 of 67 vendors on VirusTotal.

A successful attack of this nature poses a significant threat: direct financial loss through fraudulent transactions, a comprehensive data breach from stolen credentials, and severe reputational damage. Recommended immediate actions: block the attacker's indicators and issue a company-wide advisory. Long-term: enforce DMARC, deploy attachment sandboxing, and ensure EDR coverage.

1. Introduction

This report analyses a simulated phishing email delivered to a corporate mailbox in a training environment. The objective is to deconstruct the email's characteristics, identify its red flags, and translate the findings into concrete defensive recommendations.

2. Technical Analysis and Methodology

2.1 Analysis Environment

All analysis was performed inside an isolated virtual machine so that no malicious code could interact with the host or any network. Snapshots allowed a clean rollback after each step.

- Virtualisation platform: VMware Workstation
- Operating system: Kali Linux

2.2 Email Parsing and Artifact Extraction

The email was exported to .eml format, which preserves the full raw source — headers, body and attachments. The eml_parser utility (with a supporting Python script) converted the raw data into a structured, readable format without rendering active content such as HTML or embedded scripts, mitigating the risk of accidental execution.

- Acquisition — export the .eml sample and transfer it into the VM.
- Parsing — headers (From, Subject, Date, Message-ID, Return-Path), body (plain + HTML), embedded URLs, attachments (saved and hashed with MD5 / SHA1 / SHA256).
- Outputs — a metadata summary, per-message structured JSON, and saved artifacts with cryptographic hashes for threat-intel lookups.



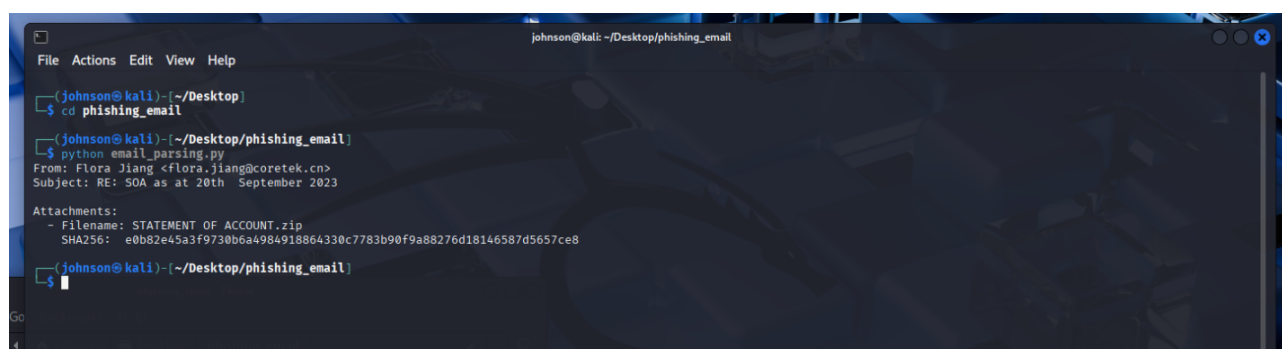
```
johnson@kali: ~/Desktop/phishing_email
File Actions Edit View Help

(johnson@kali)~[/Desktop/phishing_email]
$ unzip phishing_email.zip
Archive:  phishing_email.zip
[phishing_email.zip] phishing.eml password:
inflating: phishing.eml
inflating: phishing_analysis.py
inflating: phishing_analysis2.py
inflating: malware_traffic.pcap

(johnson@kali)~[/Desktop/phishing_email]
$ ls -l
total 1436
-rw-r--r-- 1 johnson johnson 15118 Jan 28 2025 malware_traffic.pcap
-rw-rw-r-- 1 johnson johnson 647 Jan 28 2025 phishing_analysis2.py
-rw-rw-r-- 1 johnson johnson 558 Jan 28 2025 phishing_analysis.py
-rwxrwxr-- 1 johnson johnson 625755 Nov 4 13:53 phishing_email.zip
-rw-r--r-- 1 johnson johnson 815951 Jan 26 2025 phishing.eml

(johnson@kali)~[/Desktop/phishing_email]
$
```

Parser script preparing extraction of email artifacts.



```
johnson@kali: ~/Desktop/phishing_email
File Actions Edit View Help

(johnson@kali)~[/Desktop]
$ cd phishing_email

(johnson@kali)~[/Desktop/phishing_email]
$ python email_parsing.py
From: Flora Jiang <flora.jiang@coretek.cn>
Subject: RE: SOA as at 20th September 2023

Attachments:
- Filename: STATEMENT OF ACCOUNT.zip
  SHA256: e0b82e45a3f9730b6a4984918864330c7783b90f9a88276d18146587d5657ce8

(johnson@kali)~[/Desktop/phishing_email]
$
```

Parser output — extracted sender, subject, attachment filename and SHA256.

3. Detailed Threat Analysis

3.1 Header Analysis — Evidence of Spoofing

- Authentication failure: the Authentication-Results header returned `spf=fail` — the sending IP was not authorised to send mail for the claimed domain, a strong indicator of a forged ("spoofed") sender.
- Suspicious originating IP: the Received chain confirmed the email originated from an IP geolocating to a region inconsistent with the purported sender's legitimate operations.

3.2 Content Analysis — Social Engineering

- Subject line used a RE: prefix to fake a pre-existing conversation and lower suspicion.
- Urgency and context: a "Statement of Account" lure asking to "confirm the balance due" — a classic Business Email Compromise (BEC) tactic targeting finance/admin staff.
- Generic language: impersonal salutation and sign-off, lacking the specifics of genuine business correspondence.

3.3 Attachment Analysis — Malware Confirmation

Attachment: STATEMENT OF ACCOUNT.zip

SHA256: e0b82e45a3f9730b6a4984918864330c7783b90f9a88276d18146587d5657ce8

The hash was submitted to VirusTotal and cross-checked on Tria.ge. The result was unequivocal: 50 of 67 vendors flagged the file as malicious. Notable detections: Trojan:MSIL/AgentTesla (Microsoft, AhnLab-V3), Trojan.GenericKD (BitDefender, ESET), Malicious - High Confidence (Deep Instinct).

VirusTotal detection verdict — flagged malicious by a consensus of vendors, family: agenttesla.

VirusTotal community confirmation of the Agent Tesla family.

Tria.ge cross-check — matching filename and Agent Tesla tags.

Signatures

Execution Persistence Privilege Escalation Discovery Collection

AgentTesla
Agent Tesla is a remote access tool (RAT) written in visual basic.

AGENTTESLA KEYLOGGER TROJAN STEALER SPYWARE

Agenttesla family

AGENTTESLA

Command and Scripting Interpreter: PowerShell • 1 TTPs 2 IoCs
Run Powershell to modify Windows Defender settings to add exclusions for file extensions, paths, and processes.

EXECUTION

Checks computer location settings • 2 TTPs 1 IoCs
Looks up country code configured in the registry, likely geofence.

Accesses Microsoft Outlook profiles • 1 TTPs 3 IoCs

COLLECTION

Looks up external IP address via web service • 2 IoCs
Uses a legitimate IP lookup service to find the infected system's external IP.

Suspicious use of SetThreadContext • 1 IoCs

Enumerates physical storage devices • 1 TTPs
Attempts to interact with connected storage/optical drive(s).

System Location Discovery: System Language Discovery • 1 TTPs 5 IoCs
Attempt gather information about the system language of a victim in order to infer the geographical location of that host.

DISCOVERY

Scheduled Task/Job: Scheduled Task • 1 TTPs 1 IoCs
Schtasks is often used by malware for persistence or to perform post-infection execution.

PERSISTENCE EXECUTION

Suspicious behavior: EnumeratesProcesses • 17 IoCs

Suspicious use of AdjustPrivilegeToken • 4 IoCs

Suspicious use of WriteProcessMemory • 17 IoCs

outlook_office_path • 1 IoCs

outlook_win_path • 1 IoCs

Tria.ge behavioural signatures — keylogging, credential access, persistence (score 10/10).

Agent Tesla is a .NET-based information stealer capable of logging keystrokes, capturing screenshots, accessing the clipboard, and exfiltrating credentials from browsers, email clients and other applications via HTTP(S), SMTP, FTP or Telegram (source: Malpedia).

3.4 Conclusion of Analysis

A failed SPF check, a suspicious originating IP, deceptive social-engineering tactics, and a consensus malware identification (Agent Tesla) together confirm this was a malicious phishing attack intended to compromise the recipient's workstation and steal sensitive information.

4. Business Impact and Recommendations

4.1 Business Risk ("So what?")

- Financial loss — stolen accounting/banking credentials enabling fraudulent transfers, altered payroll, or fake invoices.
- Comprehensive data breach — Agent Tesla harvests credentials from browsers, email clients and VPNs.
- Reputational damage — a public breach or fraud event erodes client and partner trust.
- Gateway for further attack — stolen credentials are frequently reused for ransomware or persistent intrusion.

4.2 Recommendations

Immediate (tactical):

- Block IOCs on the email gateway, firewalls and web proxies (sender domain, originating IP, attachment SHA256).
- Issue a company-wide advisory using this de-identified case, highlighting the red flags.
- Targeted awareness for Finance/Accounts, the high-value targets of "Statement of Account" lures.

Long-term (strategic):

- Enforce DMARC (p=quarantine or p=reject) — this alone would have blocked an email that failed SPF.
- Attachment sandboxing — detonate attachments in isolation before delivery.
- EDR coverage on all endpoints to detect and block Agent Tesla behaviour.

4.3 Incident Response and Threat Hunting

Scenario A — a user executed the file: isolate the machine from the network; force a credential reset across the user's accounts; run forensic analysis for scope and C2 communication; wipe and re-image from a known-good source; hunt for use of the compromised credentials across logs.

Scenario B — finding other recipients: search inbound mail logs for the originating IP, the attachment hash and the subject line; quarantine and delete matches; escalate any interacted-with emails into the Scenario A process.

MITRE ATT&CK; Mapping

Tactic	Technique
Initial Access	T1566.001 — Spearphishing Attachment
Execution	T1204.002 — User Execution: Malicious File
Credential Access	T1555 — Credentials from Password Stores; T1056.001 — Keylogging
Collection	T1113 — Screen Capture; T1115 — Clipboard Data
Exfiltration	T1048 — Exfiltration Over Alternative Protocol
Defense Evasion	T1036 — Masquerading (SOA lure)

Indicators of Compromise (IOCs)

Type	Value
Sender domain	coretek.cn (spoofed)
Originating IP	193.42.33.171
Attachment	STATEMENT OF ACCOUNT.zip
SHA256	e0b82e45a3f9730b6a4984918864330c7783b90f9a88276d18146587d5657ce8
Malware family	Agent Tesla (.NET infostealer)

IOCs are publicly documented on VirusTotal, Tria.ge and Malpedia.